Compte rendu de test de sécurité sur le réseau de CamTrust Bank

NKOUMOU TJADE Grinnel Germain ETOUNDI Ferdinand Le Grang

Dépôt : github.com/nkoumougrinnel/enix-ecnsa-labs

24 octobre 2026

1 Résumé pour la direction

L'évaluation porte sur un laboratoire reproduisant le réseau fictif de CamTrust Bank. Cinq services ont été analysés : web, FTP, Telnet, SNMP et DNS. Les captures révèlent des identifiants récupérables sans déchiffrement sur HTTP, FTP et Telnet. SNMP v2c expose la communauté `public` et des informations système ; les échanges DNS sont lisibles. Ces observations révèlent des risques de divulgation d'informations et de compromission des accès. La priorité est de migrer vers HTTPS, SFTP ou FTPS, SSH v2 et SNMPv3 chiffré, puis de désactiver les anciens protocoles après validation.

2 Périmètre et autorisation

Élément	Description
Environnement	Laboratoire pédagogique reproduisant le réseau fictif de CamTrust Bank. Les équipements virtuels sont exécutés dans EVE-NG, lui-même installé dans une machine virtuelle hébergée sur le poste hôte à l'aide de VMware Workstation.
Périmètre	Siège de Yaoundé : LAN 10.10.10.0/24, SW-SIEGE, R-SIEGE, CLIENT-LINUX et PC-SIEGE. Agence de Douala : LAN 10.20.10.0/24 et R-DLA, reliée au siège par la liaison privée simulée 172.16.12.0/30. Internet simulé : R-FAI et SRV-INTERNET (203.0.113.10).
Hors périmètre	Tout équipement ou réseau extérieur au laboratoire, notamment les infrastructures de production. Aucun hôte extérieur au laboratoire n'a été scanné.
Type de test	Observation passive du trafic à partir de captures de paquets analysées avec Wireshark, complétée par des connexions de test initiées depuis les postes clients du laboratoire.
Date	24 octobre 2026.
Autorisation	Travaux réalisés exclusivement dans le cadre du laboratoire pédagogique de la formation à la certification ECNSA, sous l'encadrement de l'enseignant M. MOUNIR NJI Amine. Les opérations sont limitées aux équipements virtuels du périmètre décrit ci-dessus.

Table 1 – Périmètre et cadre de réalisation des tests

Outils utilisés

Outil	Utilisation dans le laboratoire
EVE-NG	Exécution de la topologie virtuelle. Ressources allouées à la VM : 6 Go de RAM et 4 vCPU.
VMware Workstation	Hébergement de la machine virtuelle EVE-NG.
Wireshark	Capture et analyse des échanges ARP, DHCP, DNS, TCP, HTTP, FTP et SNMP.
Cisco IOSv / IOSvL2	Émulation du routeur R-SIEGE et du commutateur SW-SIEGE.
MikroTik CHR 7.23.8	Émulation du routeur R-DLA de l'agence de Douala.
VyOS	Émulation du routeur R-FAI représentant le fournisseur d'accès Internet.
Ubuntu Server 22.04	Système du serveur SRV-INTERNET (Apache, vsftpd et dnsmasq) et du poste CLIENT-LINUX.
`curl`, `dig`, `snmpwalk`, `telnet`	Génération des échanges applicatifs à analyser.
`base64`	Décodage de la valeur transmise dans l'en-tête HTTP `Authorization: Basic`.
VPCS	Émulation des postes légers PC-SIEGE et PC-DLA.

Table 2 – Outils et environnements utilisés dans le laboratoire

3 Constats

Service / protocole	Observation dans les captures	Remédiation proposée	Effort indicatif
Espace agents web HTTP, port 80	La requête `GET /admin` et l'en-tête `Authorization: Basic` sont visibles. Le décodage de sa valeur avec `base64 -d` révèle l'identifiant `agent` et son mot de passe.	HTTPS (TLS)	1 jour
Transfert de fichiers FTP	Les commandes `USER` et `PASS` révèlent l'identifiant `agentftp` et son mot de passe.	SFTP (SSH) ou FTPS	1 à 2 jours
Administration du routeur Telnet	Les identifiants de connexion et les commandes saisies sont lisibles dans le flux capturé.	SSH v2	1 jour
Supervision SNMP v2c	La communauté `public` est visible. Les réponses exposent le nom, la description et le contact du routeur.	SNMPv3 avec authentification et chiffrement	1 jour

Table 3 – Synthèse des constats et des remédiations proposées

Preuves

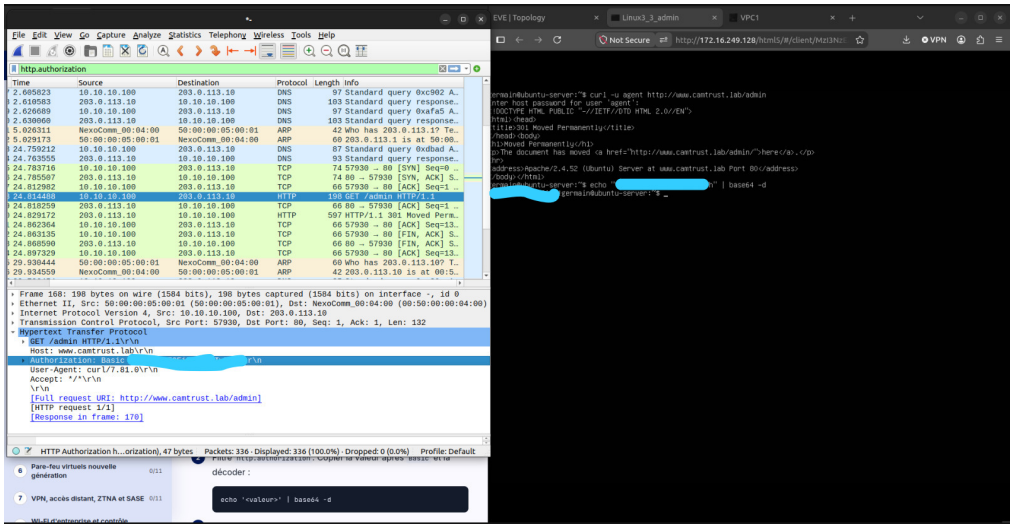


Figure 1 – HTTP : en-tête `Authorization` visible, identifiant et mot de passe lisibles après décodage (mot de passe flouté).

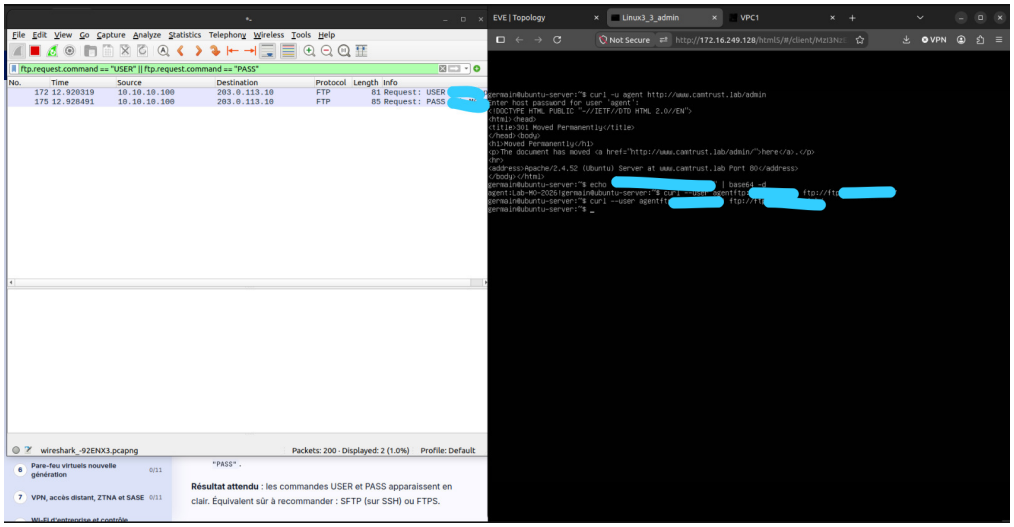


Figure 2 – FTP : commandes `USER` et `PASS` capturées en clair (identifiants floutés).

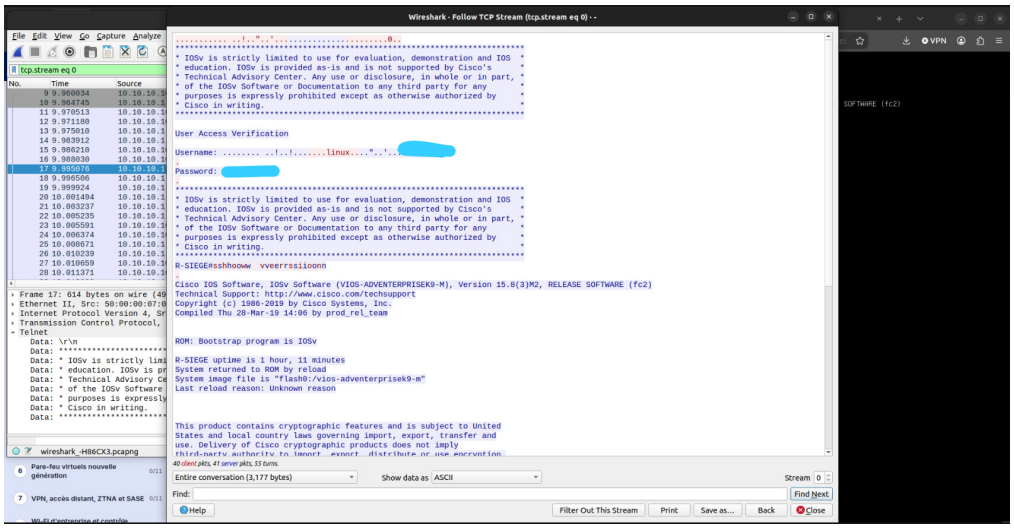


Figure 3 – Telnet : identifiants de connexion et commandes d'administration visibles en clair dans la capture.

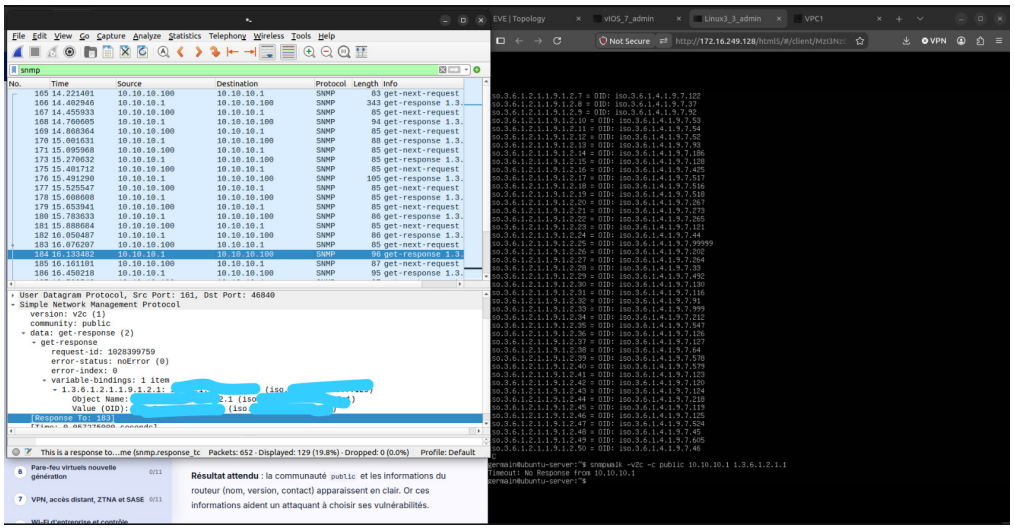


Figure 4 – SNMP v2c : communauté `public` et réponses `get-response` avec les données système du routeur.

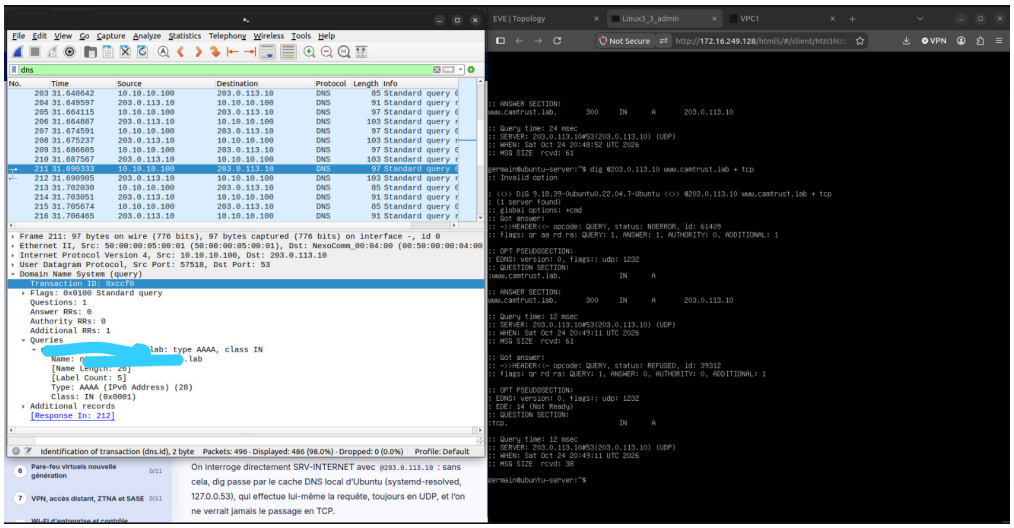


Figure 5 – DNS : requête et réponse en clair sur UDP 53 (identifiant de transaction visible).

4 Plan d'action

Service	Risque constaté	Correction proposée	Effort indicatif	Module du cours
HTTP	Identifiants de l'espace agents récupérables par un acteur capable d'intercepter le trafic.	Déployer HTTPS avec un certificat adapté. Après validation, rediriger HTTP vers HTTPS et activer HSTS.	1 jour	
FTP	Identifiants transmis en clair et absence de confidentialité des transferts.	Remplacer FTP par SFTP ou FTPS. Désactiver le service FTP non chiffré après validation des accès et des transferts.	1 à 2 jours	
Telnet	Identifiants et commandes d'administration visibles dans les échanges capturés.	Activer SSH v2 et vérifier les accès. Configurer ensuite les lignes VTY avec `transport input ssh` pour interdire Telnet.	1 jour, hors mise à jour éventuelle	
SNMP v2c	Communauté `public` et informations système visibles dans les captures.	Migrer vers SNMPv3 avec authentification et chiffrement. Désactiver v2c après validation et limiter les accès aux serveurs de supervision.	1 jour	
DNS	Noms demandés et réponses DNS visibles par un acteur capable d'intercepter les échanges.	Étudier le chiffrement des échanges DNS avec un résolveur approuvé, notamment par DNS-over-TLS, selon les capacités des clients.	1 jour pour l'étude	

Table 4 – Plan d'action proposé à partir des constats du laboratoire

5 Annexes

— Configurations finales de R-SIEGE, R-DLA et R-FAI (dossier `configs/`).
— images `B1-arp.pcapng`, `B2-dhcp.pcapng`, `B3-dns.pcapng`, `B4-tcp.pcapng`.
— images `C1-http.pcapng`, `C2-ftp.pcapng`, `C3-telnet.pcapng`, `C4-snmp.pcapng`.